



What we added, and what it means

Everything delivered after 18 September — in plain language, with the screens it changed.

19 September 2026 · commits `5607e628` → `5a163cc7` · verified against the live deployment, not a local build

2 BLOCKING DEFECTS FIXED	1 LIVE SECURITY EXPOSURE CLOSED	122 AUTOMATED TESTS PASSING	130 ms WARM API RESPONSE
---------------------------------------	--	--	------------------------------------

Section 11 of the execution plan stops at 18 September. This section continues the record. Two of the entries below are defects that would have stopped the pilot outright, one is a security exposure that was live in production, and the rest is new capability and polish.

1 Payment now completes end to end WAS BLOCKING

IN PLAIN WORDS

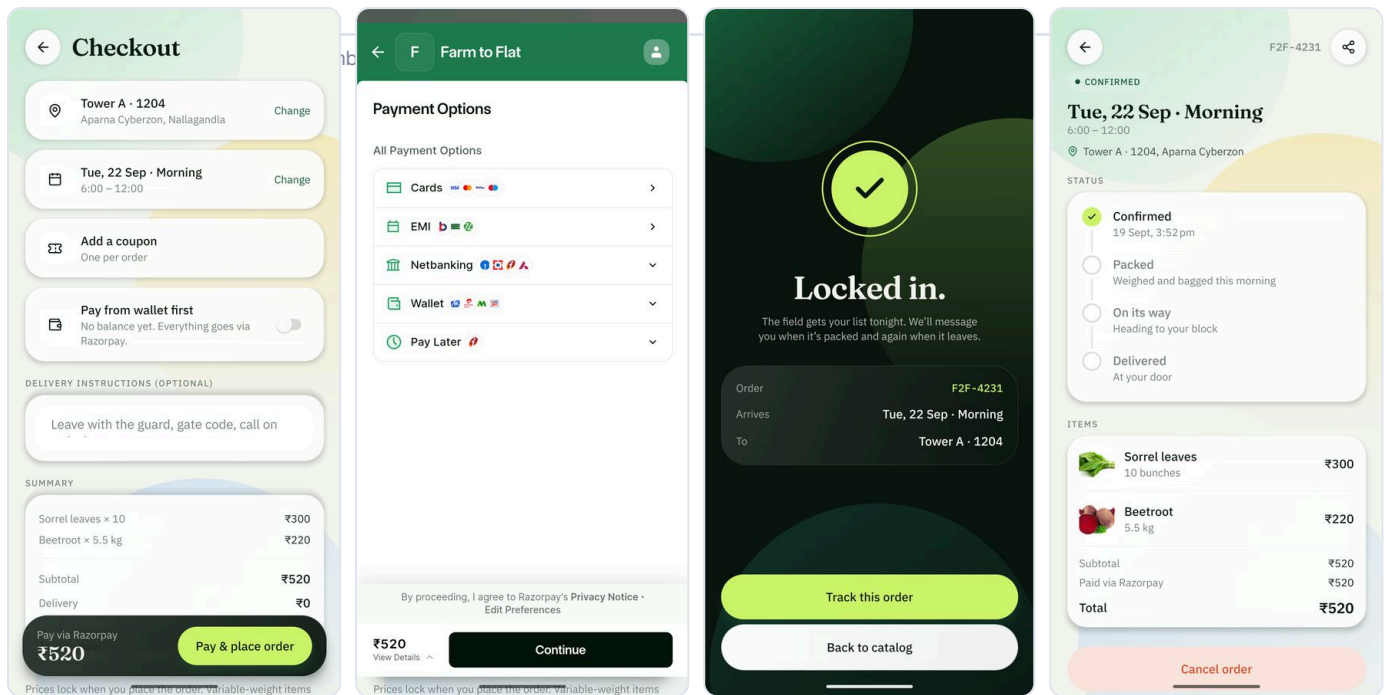
Customers could not pay. Two separate faults, either one enough to stop the business — both fixed and proven with a real order.

The cloud build shipped without the gateway key

Public settings live in a file that is deliberately kept out of version control, and that file never reaches a cloud build. The build fell back to a placeholder key, the app judged it invalid, and checkout dead-ended on “Payment unavailable”. The order then sat unpaid until the system cancelled it half an hour later. Fixed by declaring those values in the build profile, plus a pre-flight check that now fails the build if one is missing — confirmed to catch the original fault.

The payment signature was never sent back

Returning from the payment sheet, the app sent only the payment id — never the signature that proves the payment is genuine. With real credentials in place the server checked a signature it had never been given, so **every successful payment was rejected** and the customer’s money sat against an order that then cancelled itself. It stayed hidden for months because no environment had real gateway credentials; without them that check is skipped entirely. It would have surfaced the instant live keys were switched on.



Checkout

Address, window and amount confirmed before paying.

Real payment sheet

The live gateway, opened with the correct key.

Order placed

F2F-4231 — the order that proved the fix.

Confirmed, and paid

"Paid via Razorpay ₹520", recorded server-side.

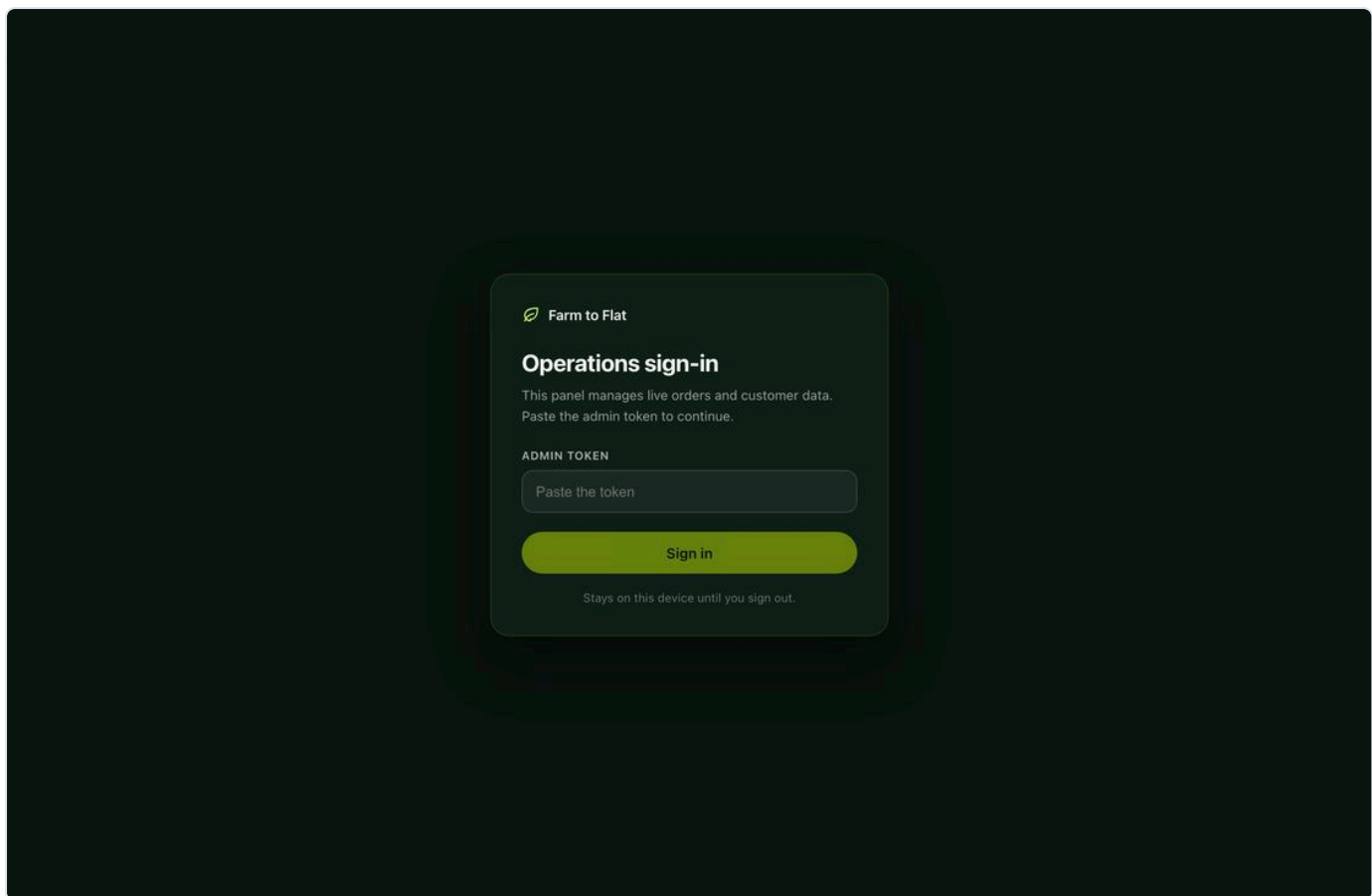
2 The operator panel required no login SECURITY

IN PLAIN WORDS

Anyone with the web address could see the whole business — today's revenue, every order, and every customer's name, phone number and home address. It now asks who you are.

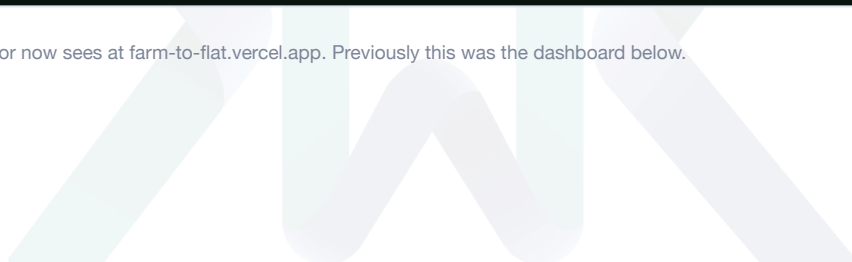
The cause was a build-time setting. The bundler writes such values into the page's JavaScript as plain text, so the admin password was readable by anyone who looked at the source, and could be copied out and used directly against the system. It had been that way for as long as the site had been online.

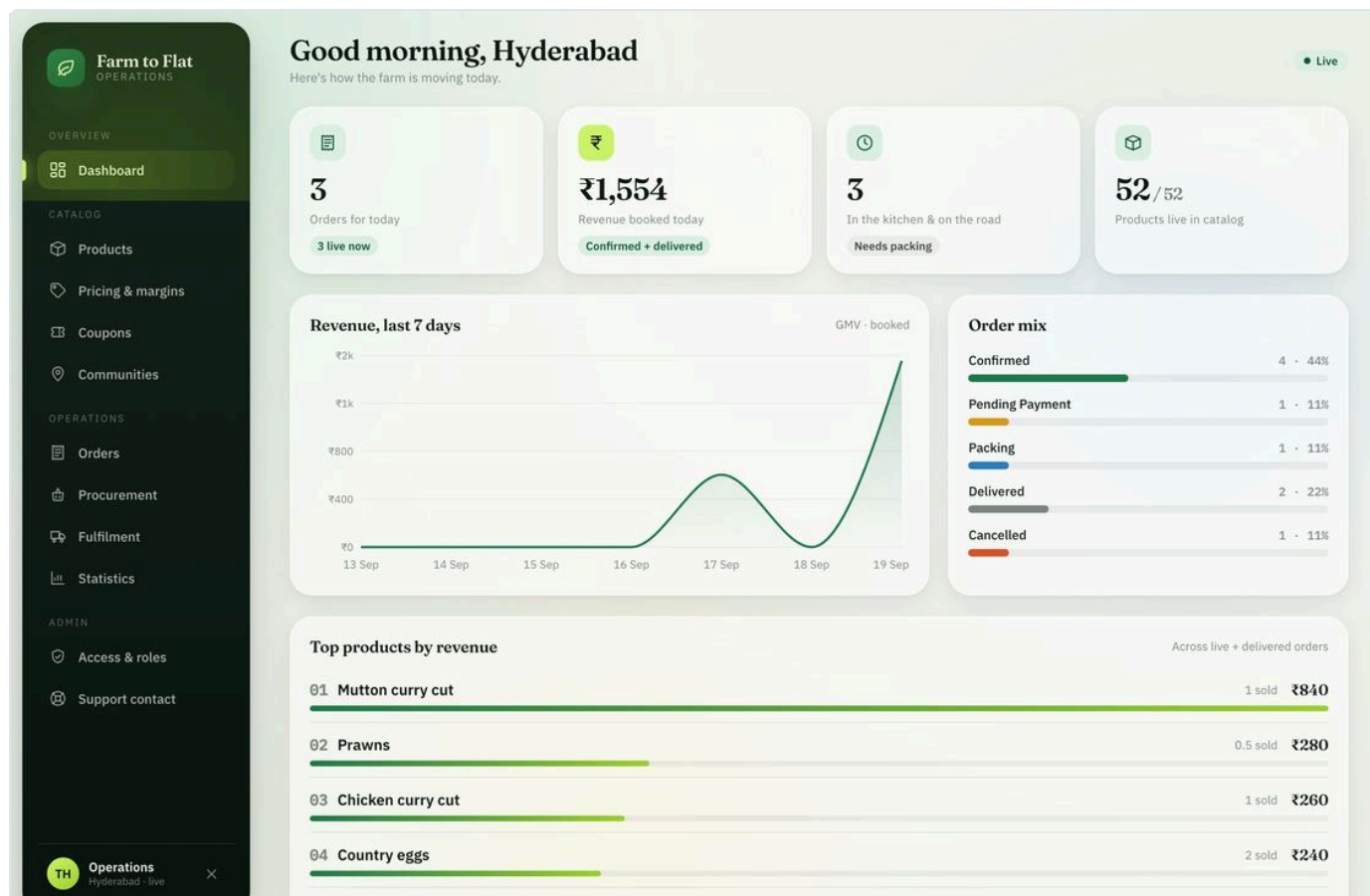
The password now lives only in the signed-in operator's own browser. Nothing secret ships in the page, a visitor who is not signed in sees a sign-in screen, and a password that stops working signs the panel out cleanly instead of failing silently. The public pages customers need — privacy and terms — stay open to everyone. **The exposed password has since been rotated**, which is what actually revokes it; the code change alone does not.



The new sign-in gate

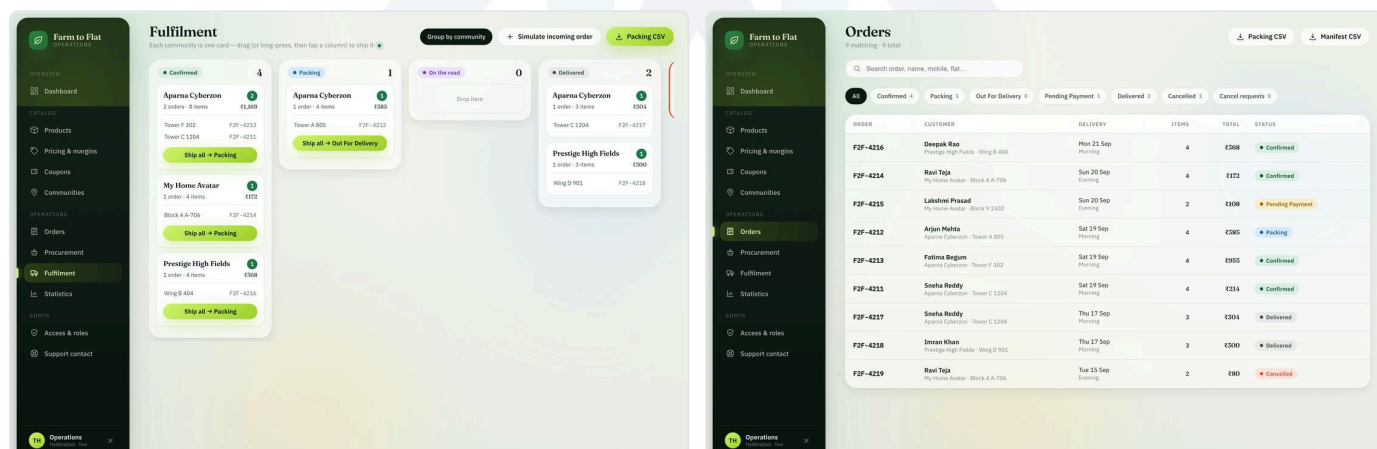
What an unauthenticated visitor now sees at farm-to-flat.vercel.app. Previously this was the dashboard below.





Operations dashboard

Revenue, order mix and top products — now behind the sign-in. Shown here with local sample data rather than real customer records.



Fulfilment board

Orders grouped by community, moved column to column as they are packed and delivered.

Orders

Filter by state, export packing and manifest sheets, open any order for its full history.

3 Protection against abuse of the public API NEW

IN PLAIN WORDS

Nothing stopped one machine requesting thousands of login codes. Once real SMS is switched on, that is somebody else spending your money. There are now limits.

Throttling by phone number already existed, so guessing one person's code was impractical. What was missing was everything else — and a ceiling on total traffic.

CONTROL	LIMIT	WHY THAT NUMBER
Login code requests, per phone number	5 / 15 min	Existing; blocks code guessing
Login code requests, per network address	60 / 15 min	Deliberately loose — Indian mobile networks put many people behind one address
Code checks, per network address	90 / 15 min	Allows honest retries, stops sweeps
All requests, per network address	600 / min	Global ceiling, adjustable without a new release

The service was also taught to trust its hosting proxy. Without that, every request looks like it comes from the proxy itself, and any per-address rule throttles all customers as one — worse than having no limit at all.

Holds only while there is one server process

These counters live in memory. Adding a second copy of the service silently doubles every limit here.

4 The staff roles could not be signed into at all WAS BLOCKING

IN PLAIN WORDS

Procurement, Fulfilment, Admin and Super admin were completely unreachable. The whole operator side of the app could not be opened, let alone tested.

A number registered as staff was deliberately excluded from the fixed test code. With no SMS provider connected there was nothing to deliver the random code it was given instead — so those accounts had no way in. Confirmed before the fix: the super-admin and procurement numbers both rejected the test code while an ordinary customer number accepted it.

All six staff accounts now sign in and open the correct role. The allowlist setting also changed meaning usefully: it now confines access to the numbers named on it, rather than being a list only staff needed. Adding staff numbers to it before would have locked out every customer tester.

The cost of this, stated plainly

While the fixed test code is enabled, anyone who guesses a staff number can sign in as that role. It must be removed before any public release.

OVERVIEW

Dashboard

CATALOG

Products

Pricing & margins

Coupons

Communities

OPERATIONS

Orders

Procurement

Fulfillment

Statistics

ADMIN

Access & roles

Support contact

TH

Operations

Hyderabad · live

Procurement

What to buy for the open orders · quantity + buffer, rounded to purchase units

Purchase list CSV

Cost-buffer approval

Auto-approve within ±2% of the estimate

2

%

Save

Approval mode

Auto-approve on

If the price paid is within this band of the estimate, the buy is approved automatically. Outside it, it waits here for your approval.

Awaiting approval

Nothing waiting — everything's within budget.

₹2,554

Estimated to procure

18

Distinct products

0/18

Bought so far

5

Open orders covered

Delivery day

All open

Sat 19 Sep

Sun 20 Sep

Mon 21 Sep

Run buffer

auto

%

Tick each item as you buy it. To procure = ordered + buffer, rounded up to a whole purchase unit (kg in half-kilos) — buffer covers spoilage, trim and short weight.

Leafy greens

1 items · ₹48.75

PRODUCT	ORDERED	BUFFER	TO PROCURE	EST. COST
S Spinach Shamshabad belt · 1 order	2 bunch	18 % +0.36 bunch	3 bunch	₹48.75

Vegetables

5 items · ₹298.08

PRODUCT	ORDERED	BUFFER	TO PROCURE	EST. COST
B Beetroot Ooty sourcing · 1 order	0.5 kg	8 % +0.04 kg	1 kg	₹28.80

Spend by source

Two goats ≈ 30 kg ₹1,033.20
1 item

Coastal sourcing ₹459.20
1 item

Farm-raised, Chevella ₹319.80
1 item

Market sourcing ₹196.56
3 items

Procurement

What to buy for the open orders — one of the screens that could not be reached before this fix.

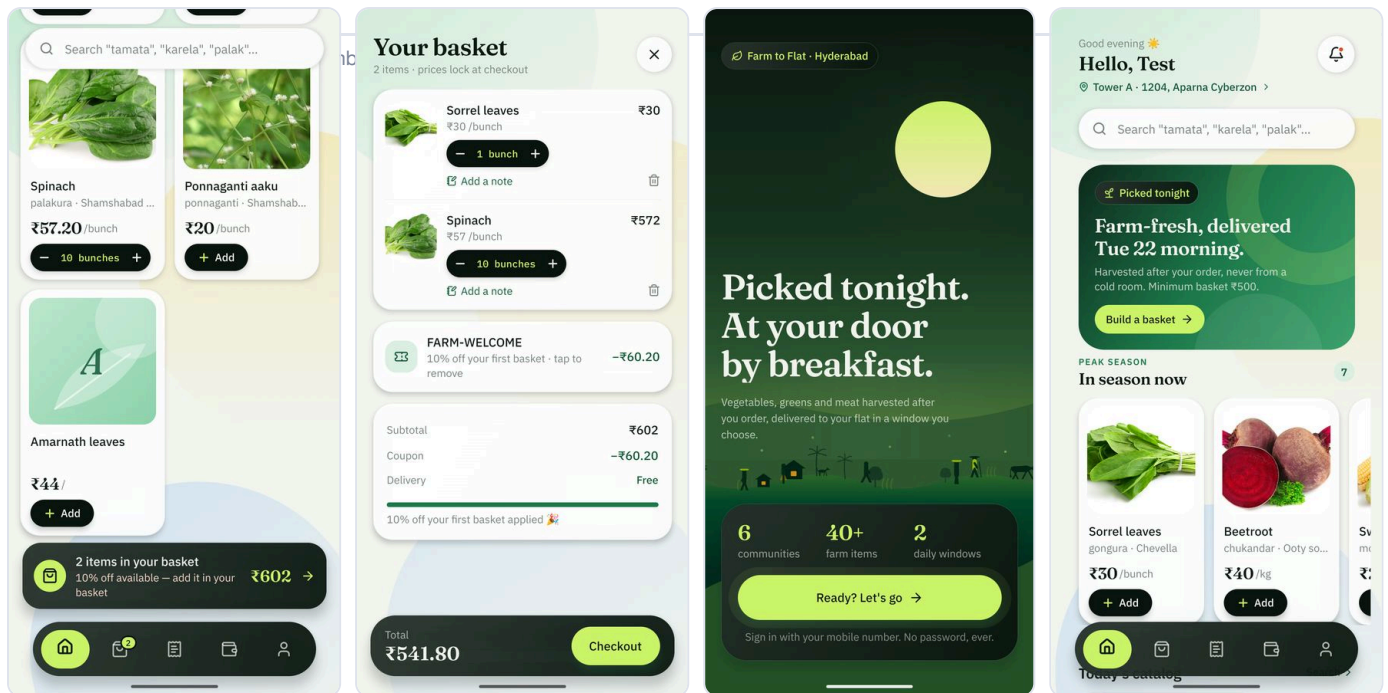
5 The basket stopped promising a discount it did not apply

IN PLAIN WORDS

The app congratulated shoppers on unlocking every offer while charging them full price. Offers have to be applied — so now it says so, and shows where.

Qualifying for an offer changes nothing until it is added. The wording now names the coupon once it is applied, or tells the shopper one is waiting and where to take it. The discount itself was never broken: applying one deducts **₹60.20** from a ₹602 basket, giving ₹541.80. Offers the basket already qualifies for read “Ready to apply” instead of “Spend ₹500 to unlock”.

A live **100% off** coupon was also found published to every customer, redeemable by anyone who opened the offer list. It had never been used, and has been switched off.



Honest prompt

"10% off available — add it in your basket."

Applied, and visible

₹60.20 shown as a line, total ₹541.80.

Welcome screen

An animated village that walks along the hill line.

Today's catalog

Live produce, prices and delivery window.

6 Smaller corrections, and how it performs

WHAT TESTERS HIT	WHAT HAPPENS NOW
A red error stayed under a field they had already corrected	Clears as they type; other invalid fields keep theirs
Notification request reappeared on every single launch	Asked once, and only while the phone still offers it
The first action of the day looked frozen for up to a minute	The app now says it is waking the server
Offers already qualified for still read "Spend ₹500 to unlock"	"Ready to apply"

Warm, the system answers in about **130–150 ms** — the application is not slow. What feels like lag is the hosting plan: the server sleeps after about fifteen minutes unused and takes roughly **50 seconds** to wake. Moving off the free plan is what removes that wait; until then the app explains it rather than appearing broken. **103** server tests and **19** app tests pass, and all eleven operator screens were walked on the live site with no failed request and no error.

7 Still outstanding — do not read this as “done”

Farm-to-Flat · Section 12 · 19 September 2026

KIWIK · internal

ITEM	CONSEQUENCE IF SHIPPED AS IT STANDS
Remove the fixed test code; connect SMS	One code signs in as any customer — and as any staff role
Live payment credentials	No real money can move; test mode only
More than one server process	Not safe. Sessions, baskets, login codes, order numbering and the new limits all live in one process’s memory
Releases clear live baskets	Baskets are lost on restart — acceptable for testers, not for paying customers
iOS tester build	Android is the only way to distribute until the Apple account exists
Per-person operator logins	One shared password; no way to remove one person without locking out everyone
Order list loads in full	Carried over from §11.8 — fine at pilot volume, not beyond it

The first three decide whether this is a pilot or a product.

